

5CS045 Student Server

Test accounts and testing notes for the security assessment (VAPT). This document is confidential. Please delete it once testing is complete.

Test accounts

Three accounts have been created for this assessment. They will be deleted after testing finishes.

1. Admin panel account (no sudo)

Field	Value
Username	vapt_panel
Password	5Dkuaw+B0kY0eLS+DMXbdkCZ
Use for	The admin panel, and SSH as an ordinary (non-root) user

2. Student account

Field	Value
Username	vapt_student1
Password	J7zqJCJ3Atq9xi
Use for	SSH, SCP, phpMyAdmin and the student websites

3. Student account

Field	Value
Username	vapt_student2
Password	vWVrtZWhk88s3H
Use for	Same as above. Two students are provided so you can test that one student cannot reach the other's files or database.

The same password works for SSH, SCP and phpMyAdmin. If the admin panel does not open, your testing IP address may need to be added to its allow list. Contact us and we will add it.

Addresses

Registration page	https://fullstack.heraldcollge.edu.np/
Student websites	https://fullstack-student.heraldcollge.edu.np/~USERNAME/workshops/ (also /assessment/ and /exam/)
phpMyAdmin	https://fullstack.heraldcollge.edu.np/phpmyadmin/
Admin panel	https://fullstack.heraldcollge.edu.np:8443/ (IP allow-listed)
SSH and SCP	port 50222, not 22 (ssh -p 50222, scp -P 50222)
Server IP	10.80.0.250 (both host names point here)

Things to try

The main things to check, in plain terms. Please test anything else you think is useful; this is a starting point, not a limit.

Area	What to try
One student reaching another	Sign in as vapt_student1 and try to read, change or delete vapt_student2's files or database. It should fail.
A student becoming an admin	Try to get root or sudo as a student. Try to use cron or scheduled jobs (students are blocked from these).
npm and composer	Hide a command in a package's install script that tries to touch another student, then install it as a student. Try a global install (npm install -g); a student should be refused.
The sign-up page	Try a non-college email (only @heraldcollege.edu.np should work), name+1@ addresses, the rate limits, and SQL injection or XSS on the form. An account is made only after the link emailed to the address is opened and Create my account is clicked, so a made-up or someone else's address should get nothing: try forging, guessing, reusing or waiting out (1 hour) that link. Finishing a sign-up needs a college mailbox you can read.
The admin panel (port 8443)	Reach it from an address not on the allow list (should be 403). Test the 5-try lockout and the session timeout. Try injection through its forms. The vapt_panel account has no sudo, so try to turn panel access into root.
SSH	Try password brute force (fail2ban should block you unless we allow-listed your IP). Confirm root login is refused.

What we have already checked

We ran these ourselves and they held. Please retest them.

- One student cannot read, change or delete another student's files.
- npm and composer install scripts run only as the student who ran them.
- A student cannot install npm packages globally.
- The vapt_panel account has no sudo on the server.

Notes

- This is the production server before it is opened to the public. It holds test data only. There is no real student data on it.
- If you make a change that the team should know about (for example creating many accounts, or filling the disk), please tell us so we can watch or clean up.
- Contact: Sarayu Gautam, sarayu.gautam@heraldcollege.edu.np